

Introduction au Durcissement des Systèmes

Objectifs : Comprendre les enjeux du durcissement et cartographier les risques liés à l'exploitation des systèmes d'exploitation Windows et Linux.

1. Concepts de Durcissement : Définition, Objectifs et Importance

1.1 Qu'est-ce que le durcissement (Hardening) ?

Le durcissement d'un système d'exploitation est le processus consistant à sécuriser un système en réduisant sa **surface d'attaque** et ses vulnérabilités potentielles. Un OS fraîchement installé est conçu pour être facile d'accès, interopérable et fonctionnel pour le plus grand nombre, ce qui est l'exact opposé d'un système sécurisé.

Principe: Tout ce qui n'est pas strictement nécessaire au fonctionnement métier doit être désactivé ou restreint.

1.2 Les objectifs du durcissement

- **Réduction de la surface d'attaque :** Moins il y a de services qui tournent, moins il y a de failles exploitables et de portes d'entrée.
- **Défense en profondeur (Defense in Depth) :** Ne pas se reposer uniquement sur le pare-feu périmétrique (ex: le routeur de l'entreprise). Si l'attaquant s'introduit sur le réseau interne, le système lui-même doit pouvoir résister.
- **Principe de moindre privilège :** Les utilisateurs, les administrateurs et les applications ne doivent avoir que les droits strictement nécessaires à l'accomplissement de leur tâche, ni plus ni moins.
- **Auditabilité :** Un système durci doit être capable de tracer les actions sensibles et d'alerter en cas de comportement anormal (centralisation des logs).

1.3 Pourquoi est-ce si important ?

- **Les configurations par défaut sont permissives :** Mots de passe faibles autorisés, services de télémétrie actifs, partages réseau ouverts à tous par commodité, protocoles obsolètes, maintenus activés pour des raisons de rétrocompatibilité.
- **Prévention des mouvements latéraux :** Une machine bureautique ou un serveur secondaire compromis sur un réseau ne doit pas servir de tremplin (pivot) pour attaquer les serveurs critiques de l'infrastructure (ex: Contrôleur de domaine).
- **Conformité et réglementations :** De plus en plus de normes (ISO 27001, RGPD, recommandations ANSSI ou CIS Benchmarks) exigent des preuves tangibles de

durcissement des systèmes traitant des données sensibles.

2. Identification des risques associés à l'exploitation des systèmes

Chaque famille de système d'exploitation possède ses propres failles de configuration et d'architecture.

2.1 Risques fréquents sur environnements Windows

- **Authentification et privilèges :**
 - Trop d'utilisateurs standards intégrés par facilité dans le groupe "Administrateurs locaux".
 - Utilisation de mots de passe sans politique de complexité ou de longueur minimale.
- **Services et protocoles réseau :**
 - Maintien de protocoles de résolution de noms ou d'authentification obsolètes (LLMNR, NBT-NS, NTLMv1) très vulnérables aux attaques de type *Man-in-the-Middle* sur les réseaux locaux (ex: attaque avec l'outil Responder).
 - Bureau à distance (RDP - port 3389) exposé sans restriction d'IP source ni obligation d'authentification réseau (NLA - Network Level Authentication).
 - Partages administratifs activés par défaut (C\$, ADMIN\$) accessibles sans filtrage.
- **Absence de cloisonnement applicatif :**
 - PowerShell accessible à tous les utilisateurs sans politique d'exécution restrictive (ExecutionPolicy).
 - Absence de règles de réduction de la surface d'attaque (ASR rules) dans Windows Defender.

2.2 Risques fréquents sur environnements Linux

- **Accès distants (SSH) :**
 - Serveur SSH autorisant la connexion directe en tant qu'administrateur suprême (root).
 - Acceptation de l'authentification par mots de passe (souvent faibles) plutôt que de forcer l'usage exclusif de paires de clés cryptographiques.
- **Droits sur le système de fichiers :**
 - Permissions mal gérées ou trop permissives (ex: fichiers de configuration lisibles ou modifiables par tous : `chmod 777`).
 - Fichiers ou binaires avec les bits **SUID/SGID** mal surveillés. Ces bits permettent l'élévation de privilèges (si un attaquant exploite une faille dans un programme appartenant à root avec le bit SUID actif, il devient root).
- **Services et démons inutiles :**
 - Démons lancés automatiquement au démarrage (ex: serveurs d'impression CUPS, serveurs web de test, services de messagerie) qui ouvrent des ports locaux (127.0.0.1) ou pire, ouverts sur le réseau (0.0.0.0) sans aucune utilité métier.